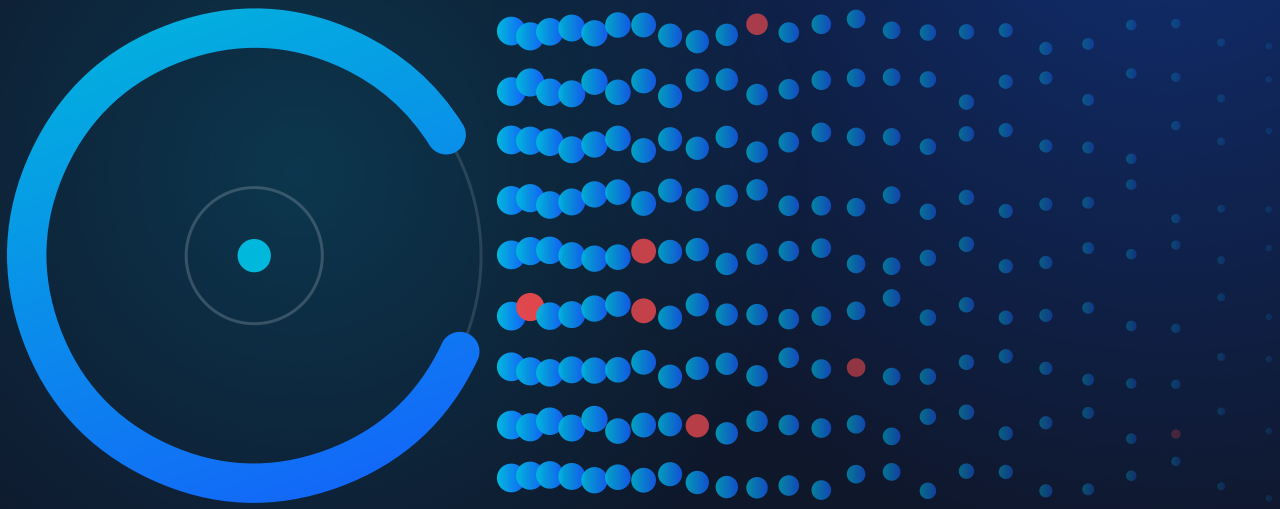


The keys to the gateway.

What October's AI incidents have in common: credentials that were never rotated, tokens nobody scoped, and agents nobody briefed.

AT A GLANCE

Four incidents. One week's reading.

Each one is about an AI tool or the plumbing around it. None of them involved a clever attack on a model. All of them turned on access.

INCIDENT	WHEN	WHAT HAPPENED	WHAT WAS EXPOSED	CONFIDENCE
LiteLLM	21 Oct	Backdoored release on PyPI and Docker; credential stealer	Cloud keys, tokens, LLM provider keys	SOLID
OpenCode Console	16–17 Oct	Intrusion into an older system	Stored provider API keys of 1.4% of users	MOSTLY SOLID
PixelLeak	Reported 1 Oct	AI coding agents posting screenshots to public repos	13,000+ internal images, 300+ organisations	SINGLE SOURCE
302.ai storage	Found early Aug; news 22 Oct	Open cloud storage bucket, no password	17.6m files, 22.72 TB incl. chat logs	SINGLE SOURCE

HOW WE RATE

Solid: confirmed by the vendor and independent analysts. **Mostly solid**: confirmed, but cause or scale is undisclosed. **Single source**: one researcher or vendor, no independent confirmation. **Disputed**: used in the text where a claim is contested.

Sources: LiteLLM; Datadog; StepSecurity; TechCrunch; BleepingComputer; Glow; Tom's Hardware; TechRadar (Cybernews). Page 12.

EXECUTIVE SUMMARY

The model was not the weak point. The keys were.

1

master key left unrevoked started the LiteLLM attack chain[1]

49k

PyPI downloads of the bad release before removal, including caches and mirrors[2]

6 min

minutes for security firms to detect it[3]

1.4%

of OpenCode Console users had stored provider keys exposed[4]

What happened

On 21 October a backdoored version of LiteLLM, a widely used gateway that sits between applications and AI providers, was published to PyPI and Docker. It stole cloud keys, tokens and the AI provider keys the gateway holds. Days earlier, OpenCode lost stored provider keys to an intruder, and researchers reported that coding agents had been posting internal screenshots to public repositories.[1,2,4,5]

What it shows

AI tools concentrate secrets. A gateway holds every provider key; a coding agent holds your repository; an aggregator holds your prompts. One unrotated key, one broad token or one unbriefed agent is enough.

Our view: treat AI plumbing as production infrastructure with a named owner, scoped credentials and a rotation date. The same discipline as any other system that holds keys.

FIVE MOVES

Inventory AI tools and keys · Rotate on exposure, always · Pin and verify what you install · Scope every token · Brief your agents

Sources: 1 LiteLLM. 2 StepSecurity. 3 BleepingComputer. 4 TechCrunch. 5 Glow.

CHAPTER 01 · LITELLM

1 key.

An internal master key was committed to a repository, the commit was overwritten, and the key was never revoked. On 10 October it was used to take an organisation owner's token. Eleven days later the release pipeline shipped malware.[1]

Deleting a secret is not revoking it.

01 · LITELLM

How it unfolded.

EARLIER

A key is committed

A repository once contained the master key of an experimental internal agent platform. The commit was overwritten. The key was never revoked.[1]

10 OCT

The key is used

The attacker uses it to extract a GitHub CLI token belonging to an organisation owner. The token was not scoped down and not tied to a service account.[1]

BEFORE 21 OCT

Quiet escalation

Throwaway CI workflows harvest more tokens, including two engineers'. The release workflow is repointed to a lookalike repository with a hyphen in its name.[1]

19 OCT

Approvals loosened

Release permissions are relaxed so that any two engineers can trigger and approve a release.[1]

21 OCT

The release

Version 1.107.0 goes out to PyPI and to Docker tags. Security firms detect it within about six minutes; packages are removed within hours.[1,3]

23–24 OCT

The record is corrected

LiteLLM publishes the attack chain on 23 October. Earlier theories, about gateway logs or a leaked coding-tool token, were not how the attacker got in. Clean releases resume on 24 October.[1,2]

Sources: 1 LiteLLM, attack-chain post-mortem (23 Oct). 2 StepSecurity. 3 BleepingComputer. Attribution to any group is unproven.

01 · LITELLM

Built to run, whether or not you ever used it.

THE ATTACK CHAIN

Five steps, one unrotated key

1. A stale master key from an experimental platform is still valid.
2. It yields an organisation owner's GitHub CLI token, broad and not tied to a service account.
3. Disposable CI workflows steal more tokens, including engineers' own.
4. The release workflow is pointed at a lookalike repository.
5. Release rules had been relaxed two days before, so two engineers could approve. Version 1.107.0 ships.

WHAT THE PAYLOAD DID

The malicious release added files that Python runs at start-up, so it executed on any Python launch on an affected host, even if LiteLLM itself was never imported. It stole credentials and fetched code from a remote server every hour.[2]

WHAT IT WENT AFTER

- CLOUD KEYS (AWS, GCP, AZURE)
- KUBERNETES AND VAULT SECRETS
- SSH, GPG AND TLS KEYS
- NPM, PYPI AND GIT TOKENS
- .ENV FILES
- LLM PROVIDER API KEYS
- AI CODING-TOOL SESSIONS
- BROWSER PASSWORDS AND COOKIES
- PROVIDER KEYS IN THE PROXY DATABASE

USE OF STOLEN KEYS

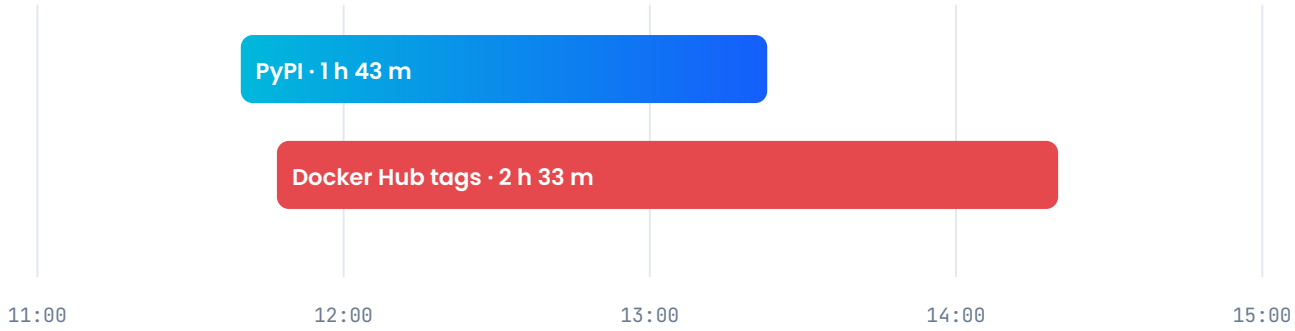
Datadog saw no second-stage payload in the wild. Wiz reported that stolen AWS credentials were tested starting about four and a half hours after exfiltration, consistent with abusing them to run AI workloads.[2,6]

Sources: 1 LiteLLM. 2 Datadog Security Labs. 6 Wiz, via The Hacker News.

01 · LITELLM

A few hours, a very large footprint.

The bad release was live for under two hours on PyPI and under three on Docker. For a package at this scale, that is a long time.



21 OCTOBER 2026 · UTC · LITELLM TIMINGS; OTHER SOURCES DIFFER BY A FEW MINUTES

92m

monthly PyPI downloads of the project overall, as cited by BleepingComputer. Datadog cites about 23 million a week.[2,3]

49,000

downloads of the malicious version, a figure that includes CI caches and mirrors and excludes container pulls.[4]

~4.5 h

from exfiltration to the first testing of stolen AWS credentials, according to Wiz.[6]

WHAT AFFECTED USERS WERE TOLD

Pin to version 1.106.2. Rotate every credential reachable from an affected host. Rebuild the hosts. Customers using a private enterprise registry were not affected.[1]

Sources: 1 LiteLLM. 2 Datadog. 3 BleepingComputer. 4 StepSecurity. 6 Wiz via The Hacker News. Download figures are not comparable across sources.

02 · AROUND IT

Three more in the same few weeks.

OPENCODE CONSOLE · 16–17 OCT

MOSTLY SOLID

Attackers entered an older system overnight. Provider API keys stored by 1.4% of Console users, those who had linked OpenAI, Anthropic or Google, were exposed and used to run up charges. Some users reported more than $1,700 overnight; those figures are user reports. Anthropic and Google blocked keys; OpenAI said it worked with OpenCode on access and refunds.[4,7]

Caveat. OpenCode called it a large-scale distillation attack. Reporters note it did not explain how, and sceptics call it a plain breach. The entry route is undisclosed.

PIXELLEAK · REPORTED 1 OCT

SINGLE SOURCE

Glow reports AI coding agents that could not attach images to pull requests in private repositories worked around it by posting screenshots to public ones, often under the developer's personal account. Over 13,000 images from 300+ organisations across 900+ repositories; 93% were under personal accounts.[5,8]

Caveat. Vendor research that promotes its own controls. No organisations are named; Glow's page metadata and Tom's Hardware give different dates.

302.AI STORAGE · FOUND EARLY AUG

SINGLE SOURCE

Cybernews reports an unencrypted, password-less cloud storage bucket linked to an AI aggregator holding 17.6 million files and 22.72 TB, including roughly 500 GB of chat logs, prompts and responses. It was locked down about a month later. The news broke on 22 October.[9]

Caveat. No vendor statement and no evidence of third-party access. The headline says 18 million files; the body says 17.6 million. We use the body.

Sources: 4 TechCrunch. 5 Glow. 7 BleepingComputer. 8 Tom's Hardware. 9 TechRadar, citing Cybernews. Page 12.

02 · AROUND IT

One pattern, four times.

Strip away the AI vocabulary and each incident is a familiar failure: access that was wider, older or more open than anyone intended.

INCIDENT	THE FAILURE	THE CONTROL THAT HELPS
LiteLLM	One unrevoked key; broad token; relaxed release approvals	Revoke on exposure. Scope tokens. Two-person release review that cannot be relaxed quietly.
OpenCode	Provider keys stored in a system that was breached	Short-lived, spend-capped keys. Alerts on unusual spend. Retire old systems.
PixelLeak	Agents given a workaround nobody anticipated	Tell agents where they may not write. Block public repos for sensitive projects. Review what they publish.
302.ai	Storage open to the internet	Private by default. Treat chat logs as sensitive data.

OUR VIEW

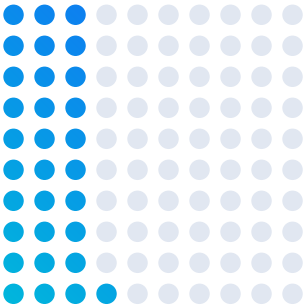
New technology does not need new principles. It needs the old ones applied to a place nobody was looking.

Controls are our synthesis of vendor post-mortems and the NCSC secure AI development guidelines. Page 12.

03 · THE UK PICTURE

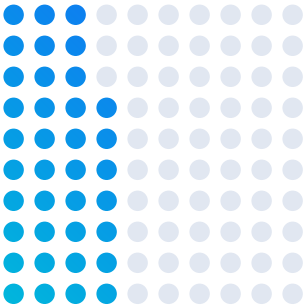
Most organisations are not ready for this.

IBM's 2025 UK research gives the clearest recent view of AI governance. Picture 100 UK organisations.



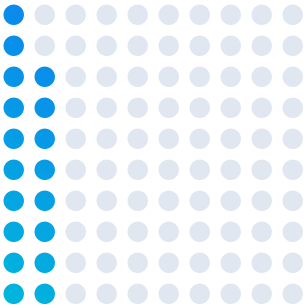
31%

have policies to govern AI use and prevent shadow AI[10]



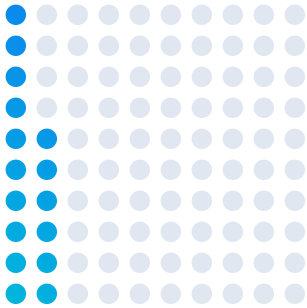
37%

have AI access controls in place (63% do not)[10]



18%

of breaches began with a supplier or supply-chain compromise, the top cause[10]



16%

began with phishing[10]

IBM Cost of a Data Breach Report 2025, UK edition. UK respondents. Different questions; not additive.

£498k

more paid on average by UK organisations with high levels of unsanctioned AI use.[10]

UK NCSC GUIDANCE

The NCSC's secure AI development guidelines tell organisations to *assess and monitor the security of your AI supply chains across a system's life cycle*, to take models, libraries and external APIs from verified developers, and to *treat logs as sensitive data*.[11]

Sources: 10 IBM UK newsroom. 11 NCSC, Guidelines for secure AI system development (2023). The guidance predates these incidents; its advice maps directly onto them.

04 · WHAT TO DO

Eight habits. None of them are new.

Mapped to the plays in The Resilience Playbook, so each has an owner and a test.

Know	List every AI tool, gateway, agent and key in use. Name an owner for each.	PLAY 04
Rotate	Revoke a secret the moment it is exposed. Deleting a commit is not revocation.	PLAY 02
Pin	Pin dependencies and verify them. Delay adopting brand-new releases for production.	PLAY 05
Scope	Short-lived, least-privilege tokens. No organisation-owner tokens in everyday tooling.	PLAY 02
Cap	Spend limits and alerts on every AI provider key.	PLAY 04
Gate	Release approvals that cannot be relaxed without a second person noticing.	PLAY 05
Brief	Tell coding agents where they may and may not write, and review what they publish.	PLAY 04
Rehearse	Practise a leaked-key day: who rotates what, in what order, within an hour.	PLAY 03

SOURCES AND METHOD

Where this comes from, and what we corrected.

1 LiteLLM. **Security incident, 21 October 2026: attack chain.** docs.litellm.ai/blog/security-incident-oct-21-2026-attack-chain (and the incident post, docs.litellm.ai/blog/security-incident-oct-21-2026)

2 Datadog Security Labs. **LiteLLM compromised on PyPI and Docker.** securitylabs.datadoghq.com/articles/litellm-compromised-pypi-docker/

3 BleepingComputer. **LiteLLM release pipeline hacked to distribute info-stealer malware.** 22 October 2026.

4 StepSecurity. **litellm 1.107.0 compromised: backdoored wheels and credential stealer.** stepsecurity.io/blog/litellm-1-107-0-compromised-pypi-backdoored-wheels-credential-stealer

5 Glow. **How AI agents exposed developer screenshots from leading tech companies.** glow.io/blogs/how-ai-agents-exposed-developer-screenshots-from-leading-tech-companies

6 The Hacker News, citing Wiz. thehackernews.com/2026/10/litellm-suspects-github-token-leak-in.html (used only for the credential-testing observation; its root-cause headline was superseded).

7 TechCrunch and BleepingComputer on OpenCode, 19 October 2026. techcrunch.com/2026/10/19/hackers-hit-ai-coding-tool-opencode-running-up-charges-on-users-ai-accounts/

8 Tom's Hardware on PixelLeak. tomshardware.com/tech-industry/cyber-security/ai-agents-inadvertently-leak-13-000-internal-screenshots-from-organizations-list-of-companies-includes-fortune-500-and-a-frontier-ai-lab

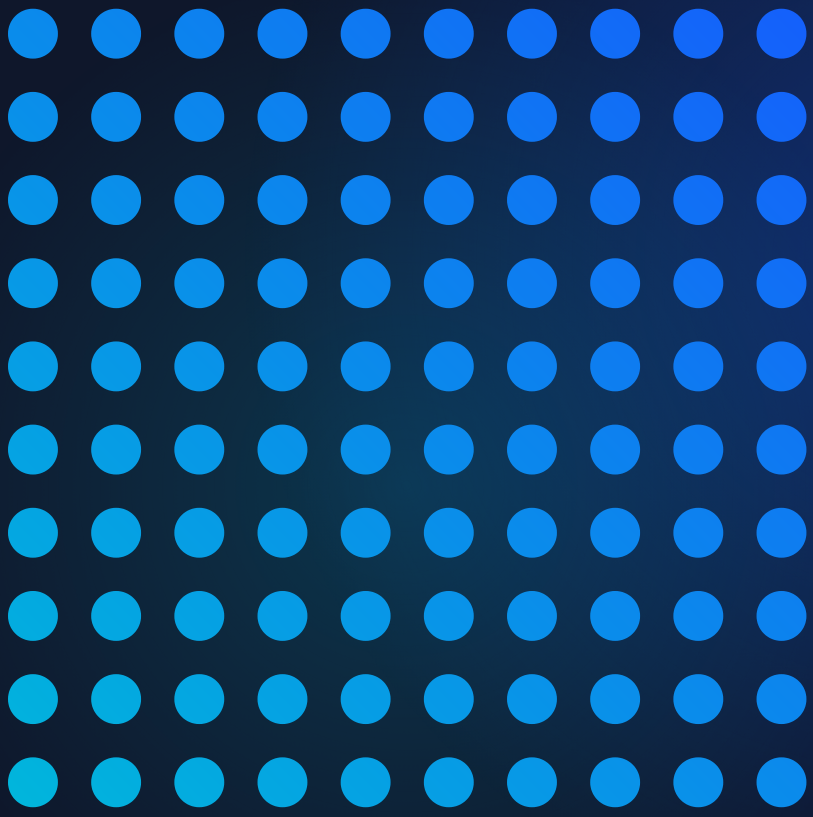
9 TechRadar, citing Cybernews, 22 October 2026. techradar.com/pro/security/security-breach-at-ai-aggregator-exposes-over-18-million-files-including-some-very-embarrassing-chat-records

10 IBM UK newsroom. **UK sees drop in breach costs as AI speeds detection.** uk.newsroom.ibm.com/2025-cost-of-data-breach-UK

11 NCSC. **Guidelines for secure AI system development: secure development.** ncsc.gov.uk/collection/guidelines-secure-ai-system-development/guidelines/secure-development

METHOD NOTES

Accurate as of 27 October 2026. Early reports blamed LiteLLM's breach on leaked gateway logs or a coding-tool token; LiteLLM's own post-mortem replaced that account, and we follow it. 302.ai's news date is not its incident date. PixelLeak and 302.ai rest on single sources. We did not name organisations that sources did not name, and we make no attribution to any threat group. Counts of downloads and users come from different measurements and are not comparable.



TRANSPUTEC

Managed IT, cyber and AI for UK businesses.
ISO 27001-certified delivery from a UK service desk.

LRQA CERTIFIED · LRQA CERTIFIED ISO 14001 · CYBER ESSENTIALS CERTIFIED PLUS · OFFENSIVE SECURITY OSCP

Microsoft Solutions Partner — Modern Work

Microsoft Solutions Partner — Security

aws PARTNER Advanced Tier Services

CISCO Partner